

L2 - 9.1. Intro to Threat Emulation

Task 1 - Introduction

Red and Blue Team exercises are important because they help organizations identify vulnerabilities, improve threat detection, and strengthen incident response capabilities through realistic security testing and collaboration.

SOC teams use simulations and emulations. These exercises provide hands-on experience, help address the cybersecurity skills gap, and improve readiness against real-world threats.

The benefit of understanding simulation vs. emulation: It helps organizations build a more effective threat detection and response program, ultimately strengthening their overall security posture.

Task 2 - What is Threat Emulation?

Threat Emulation: Mimicking of real world attacks based on intelligence and TTPs.

Threat Simulation: Threat emulation imitates specific real-world attackers and their TTPs, while threat simulation uses predefined attack patterns that represent general adversary behavior.

Purpose of Threat Emulation: Threat emulation enables organizations to evaluate their security defenses from an attacker's perspective, validate the effectiveness of security controls, improve compliance, and strengthen readiness against real-world cyber threats by testing assumptions about existing protections.

Cyber Security Assessment Issues: Traditional cybersecurity assessments—including vulnerability assessments, penetration tests, and red team exercises—help organizations identify weaknesses and evaluate defenses. However, they often fail to replicate the full attack lifecycle and may lack collaboration between Red and Blue Teams. Threat emulation addresses these gaps by simulating real-world adversary behavior, providing a more comprehensive assessment of security effectiveness.

Emulation vs Simulation: Threat emulation replicates real-world adversary behavior, including their TTPs, in a controlled environment to test and improve

security defenses. Unlike threat simulation, which uses predefined attack patterns, emulation focuses on accurately imitating specific attackers to identify security gaps and strengthen response capabilities.

The concepts include the following:

- **Real-world threats:** The MITRE ATT&CK framework and cyber threat intelligence are common information sources to ensure threat TTPs are based on actual breaches, APTs and campaigns.
- **Behaviour-focused:** The execution of TTPs during an emulation exercise aims to tune defences based on behaviours and not signatures, thus adapting to the elements of the Pyramid.
- **Transparency:** Disclosure of activities between the Red and Blue teams during execution ensures that the security posture is improved holistically.
- **Collaborative:** Due to the common goal of improving organisational security, threat emulation allows teams to collaborate in their efforts.
- **Repeatable:** Some emulation tasks would be done multiple times in the course on an exercise or numerous exercises. These tasks can be automated, creating a baseline of continuous practical security assessments and deployment.

Emulation can be applied to numerous instances, each with its own goals:

- **Assessments & Improvement:** The goal is to test personnel, assess security processes and evaluate the technology adopted.
- **Capability Development:** Emulation enables the creation, modification and application of tools and analytics derived from TTPs.
- **Professional Development:** What better way to teach and promote knowledge sharing about adversary behaviours and frameworks? This breaks down the barriers between red and blue teams and fosters collaboration missions.

Answer the questions below

What can be defined as an intelligence-driven impersonation of real-world attacks?

Threat Emulation

What is the exercise of representing adversary functions through predefined and automated attack patterns?

Threat simulation

Task 3 - Emulation Methodologies and Frameworks

Threat emulation methodologies are strategies, plans and procedures used to simulate and test network defences and systems against adversaries. There are various methodologies, each with its unique approach and level of technicality, but all share the goal of discovering weaknesses in security.

1. **MITRE ATT&CK:** The **MITRE ATT&CK Framework** is a knowledge base of real-world adversary tactics, techniques, and procedures (TTPs). Threat emulation teams use it to map attacker behaviors, improve reporting, and develop better security mitigations. The ATT&CK Matrix organizes **14 adversary tactics** from reconnaissance to impact, while the **ATT&CK Navigator** helps visualize techniques and sub-techniques used by specific attackers.
2. **Atomic Testing:** **Atomic Testing** uses the **Atomic Red Team** framework, a collection of small emulation tests designed to validate security defenses. These tests simulate malicious activities, generate telemetry, and help security teams improve detection and response. Atomic tests are mapped to the **MITRE ATT&CK Framework** and support testing across endpoints, cloud environments, and multiple platforms.
3. **TIBER-EU Framework:** **TIBER-EU Framework** is a European threat intelligence-based ethical red teaming framework that helps organizations improve cyber resilience by conducting controlled, intelligence-driven adversary emulation on critical systems. It follows three phases:
4. **Preparation Phase:** Define scope, establish teams, and obtain management approval for the test.
5. **Testing Phase:** Threat intelligence guides Red Teams in simulating real attacks, while Blue Teams detect and evaluate defenses.
6. **Closure Phase:** Teams analyze results, report findings, and recommend improvements to security controls, processes, and training.

4. CTID Adversary Emulation Library: CTID Adversary Emulation Library

provides open-source adversary emulation plans to help organizations test their defenses against real-world threats using threat-informed defense practices. It offers two approaches:

- **Full Emulation:** Replicates a specific adversary (e.g., APT29) across the complete attack lifecycle, from initial access to exfiltration.
- **Micro Emulation:** Focuses on specific attacker behaviors or techniques, such as process injection or file access.

Answer the questions below

Under TIBER-EU, under which phase would Engagement and Scoping fall?

Preparation

What is the library that provides technical emulation tests based on TTPs?

Atomic Red Team

Task 4 - Threat Emulation Process I

Scenario: VASEPY Corp is a multi-billion dollar U.S. retail establishment who are aware of the numerous cyber threats plaguing the retail industry. As a result of the news of a recent breach of one of their competitors, executives have become more concerned about the company's security posture. They have hired you as a Threat Emulation Engineer to plan and execute an adversary emulation exercise based on known threat groups that would target their business.

Developing an internal emulation engagement process for an organisation must be iterative, aligned with recorded cyber security goals, intelligence-driven, and methodical. Security teams can revisit the iterative process, make adjustments where fit and improve the exercise while emulating a given adversary. As an overview, **the process's steps for threat emulation are as follows:**

1. Define Objectives
2. Research Adversary TTPs
3. Planning the Threat Emulation Engagement
4. Conducting the Emulation

5. Concluding and Reporting

1. Defining Emulation Objectives: Set clear, specific, and measurable goals for the exercise. Define the scope, targeted systems, and data to ensure the emulation remains focused.

2. Research Adversary TTPs: Study real attacker behaviors to create a realistic emulation plan.

2.1. Information Gathering: Collect threat intelligence from internal teams, previous incidents, and public sources to identify relevant adversaries.

2.2. Select The Emulated Adversary: Choose an adversary based on:

- Relevance to the organization: Choose a threat actor that matches the organization's industry and risks.
- Available threat intelligence: Ensure enough information exists about the adversary's TTPs and campaigns.
- TTP complexity: Select techniques that match the organization's security maturity.
- Available resources: Confirm the required tools, skills, and time are available for the simulation.

2.3. Select The Emulated TTPs: Identify attacker techniques using frameworks like **MITRE ATT&CK** and prioritize behaviors that align with the objectives.

2.4. Construct TTP Outline: Document the planned attack scenarios, scope, rules of engagement, and implementation steps.

Answer the questions below

| There's a set of 3 software used by FIN6 & FIN7. Can you identify them?

AdFind, Cobalt Strike, Mimikatz

| Which factor will be considered when analysing whether to use existing or custom tools during the emulation?

TTP Complexity

Task 5 - Threat Emulation Process II

3. Planning the Threat Emulation Engagement: Threat emulation requires careful planning because it simulates real attacks and can cause risks such as data exposure, system downtime, or operational disruption.

3.1 Threat Emulation Plans: defines how the exercise will be executed and includes:

- **Engagement Objectives:** Goals and purpose of the emulation.
- **Scope:** Systems, users, and departments included in the test.
- **Schedule:** Timing of activities and deliverables to avoid business disruption.
- **Rules of Engagement:** Allowed attack behaviors, limitations, and safety measures.
- **Permission to Execute:** Formal approval to conduct the exercise legally.
- **Communication Plan:** Defined channels and procedures for coordination between teams.

4. Conducting the Emulation

Conducting the Emulation involves executing real-world attacker TTPs in a controlled environment. Skilled professionals replicate adversary behaviors while ensuring safety and addressing issues during the exercise.

4.1. Planning the Deployment: Prepare the emulation lab, define team responsibilities, and map selected TTPs using frameworks like **MITRE ATT&CK** and threat intelligence sources.

4.2. Implementation of TTP: Deploy attacker techniques, such as phishing campaigns or malicious files, to simulate real adversary behavior.

4.3. Detections & Mitigations: Blue Teams and SOC analysts monitor activities, analyze logs, detect TTPs, and apply security improvements based on findings.

Answer the questions below

The emulation plan component determining which activities are to be conducted is known as the?

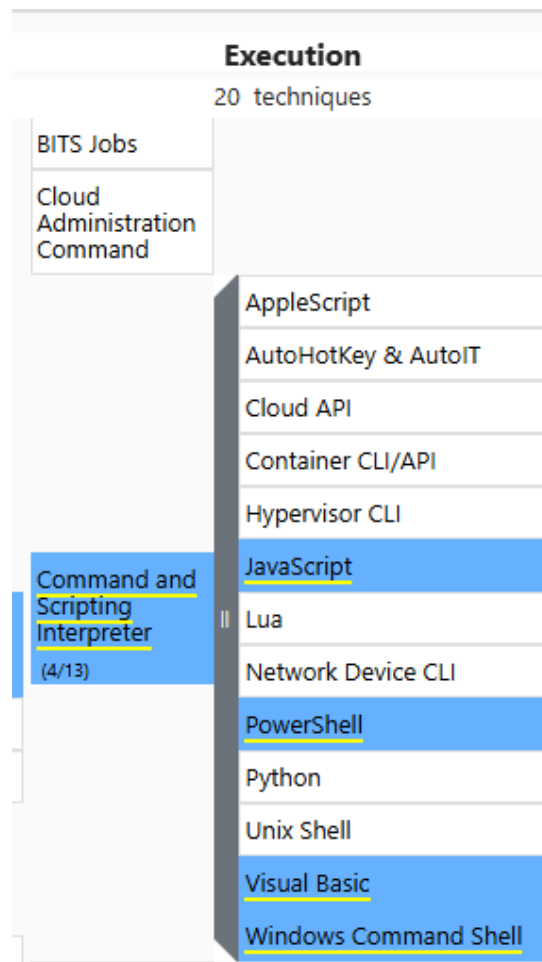
Scope

What is flag one obtained after completing the exercise?

THM{C4RB0N_\$P1D3R_1\$_F1N7}

Assuming you're emulating Carbon Spider, what will you use to achieve Execution Techniques?

According to Mitre, the Execution Techniques is Windows Command Shell



While emulating Carbon Spider, what would be used to achieve persistence?

Registry Run Keys and Startup Folder both provide persistence mechanisms, similar to Scheduled Tasks.

Persistence	
22 techniques	
Powercat	
Authentication Package	
Kernel Modules and Extensions	
Login Items	
LSASS Driver	
Port Monitors	
Print Processors	
Re-opened Applications	
<u>Registry Run Keys / Startup Folder</u>	
Security Support Provider	
Shortcut Modification	
Time Providers	
Winlogon Helper DLL	
XDG Autostart Entries	

There is a POS Malware that Carbon Spider has been known to use to harvest credit card data. What is it?

Pillowmint

VB Flash: Visual Basic-based tool/malware used for **execution or automation**.

Pillowmint: It is a **point-of-sale (POS) malware** used by cybercriminals to **steal payment card data** from infected systems.

Windows Service: A Windows background process that attackers can abuse for **persistence** by running malicious code automatically.

MITRE ATT&CK®		Matrices ▾	Tactics ▾	Techniques
GROUPS FIN6 FIN7 FIN8 Fox Kitten GALLIUM Gallmaker Gamaredon Group GCMAN GOLD SOUTHFIELD Gorgon Group Group5 HAFNIUM	S0449	Maze		Application Layer Protocol: Web Protocols, Boot and Scripting Interpreter: Windows Command Shell, Hide Artifacts: Run Virtual Instance, Indicator Removal: Native API, Obfuscated Files or Information: Junk Injection: Dynamic-link Library Injection, Schedule Msiexec, System Information Discovery, System Log Discovery, System Shutdown/Reboot, Windows M
	S0002	Mimikatz	[5]	Access Token Manipulation: SID-History Injection, Provider, Credentials from Password Stores, Credentials from Password Stores: Windows Credential Manager, OS Credential Dumping: LSASS Memory Authentication Certificates, Steal or Forge Kerberos Unsecured Credentials: Private Keys, Use Alternate Material: Pass the Ticket
	S0517	Pillowmint	[29][5]	Archive Collected Data, Command and Scripting Interpreter: Windows Command Shell, Event Triggered Execution: Application Deletion, Modify Registry, Native API, Obfuscated Obfuscated Files or Information: Fileless Storage, Registry

FIN7's ransomware program is below:

[Home](#) > [Groups](#) > [FIN7](#)

FIN7

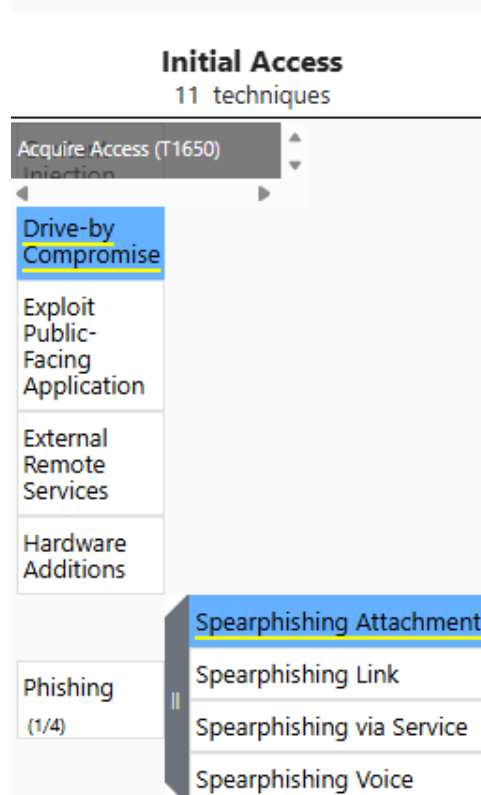
FIN7 is a financially-motivated threat group that has been active since 2013. **FIN7** has targeted the retail, restaurant, hospitality, software, consulting, financial services, medical equipment, cloud services, media, food and beverage, transportation, pharmaceutical, and utilities industries in the United States. A portion of **FIN7** was operated out of a front company called Combi Security and often used point-of-sale malware for targeting efforts. Since 2020, **FIN7** shifted operations to big game hunting (BGH), including use of **REvil** ransomware and their own Ransomware-as-a-Service (RaaS), Darkside. **FIN7** may be linked to the **Carbanak** Group, but multiple threat groups have been observed using **Carbanak**, leading these groups to be tracked separately.^{[1][2][3][4][5][6][7]}

What is flag two obtained after completing the exercise?

THM{3\$P1ON4G3_FOR_R34P3R}

Assuming you're emulating Reaper, what will you use to achieve Initial Access Techniques?

Reaper is APT 37



Reaper's Command and Control plan utilises DOGCALL malware. Which platform would be used to deploy it?

Web Service

DOGCALL is a backdoor used by APT37 that has been used to target South Korean government and military organizations in 2017. It is typically dropped using a Hangul Word Processor (HWP) exploit. It is a software that use apt

Techniques Used

ATT&CK® Navigator Layers

Domain	ID	Name	Use
Enterprise	T1123	Audio Capture	DOGCALL can capture microphone data from the victim's machine. ^[2]
Enterprise	T1105	Ingress Tool Transfer	DOGCALL can download and execute additional payloads. ^[2]
Enterprise	T1056	.001 Input Capture: Keylogging	DOGCALL is capable of logging keystrokes. ^{[1][2]}
Enterprise	T1027	.013 Obfuscated Files or Information: Encrypted/Encoded File	DOGCALL is encrypted using single-byte XOR. ^[2]
Enterprise	T1113	Screen Capture	DOGCALL is capable of capturing screenshots of the victim's machine. ^{[1][2]}
Enterprise	T1102	.002 Web Service: Bidirectional Communication	DOGCALL is capable of leveraging cloud storage APIs such as Cloud, Box, Dropbox, and Yandex for C2. ^{[1][2]}

If you were Reaper, which defence evasion technique would you use to hide information?

Steganography: A technique used to **hide data inside another file** (such as an image, audio, or document) to avoid detection.

Stealth	
30 techniques	
	Dynamic API Resolution
	Embedded Payloads
	Encrypted/Encoded File
	Fileless Storage
Obfuscated Files or Information (1/18)	HTML Smuggling
	Indicator Removal from Tools
	Invisible Unicode
	Junk Code Insertion
	LNK Icon Smuggling
	Polymorphic Code
	Software Packing
	Steganography
	Stripped Payloads
	SVG Smuggling

Initial zero day abused by Reaper was on the software? Adobe

Which software uses Reaper according to Mitre

Execution
20 techniques

Command		Boot or Log Initialization Scripts (0/5)
Deploy Container		Cloud Application Integration
ESXi Administration Command		Compromise
Exploitation for Client Execution	Exploitation for Client Execution (T1203) Score: 1 Comment:[APT37] (https://attack.mitre.org/groups/G0067) has used exploits for Flash Player (CVE-2016-4117, CVE-2018-4878), Word (CVE-2017-0199), Internet Explorer (CVE-2020-1380 and CVE-2020-26411), and Microsoft Edge (CVE-2021-26411) for execution.(Citation: Securelist ScarCruft Jun 2016)(Citation: FireEye APT37 Feb 2018)(Citation: Talos Group123)(Citation: Volexity InkSquid BLUELIGHT August 2021)	1st Softwa Binary
Hijack Execution Flow (0/12)		Create Process
Input Injection		Create or Open System Process (0/5)
Inter-Process Communication (1/3)		Event Triggered Execution

T1203

MITRE ATT&CK				
Matrices Tactics Techniques Defenses CTI Resources Benefactors Contribute				
GROUPS	Enterprise	T1189	Drive-by Compromise	APT37 has used strategic web compromises, particularly of South Korean websites, to distribute malware. The group has also used torrent file-sharing sites to more indiscriminately disseminate malware to victims. As part of their compromises, the group has used a Javascript based profiler called RICECERRY to profile a victim's web browser and deliver malicious code accordingly.[2][1][4]
	Enterprise	T1203	Exploitation for Client Execution	APT37 has used exploits for Flash Player (CVE-2016-4117, CVE-2018-4878), Word (CVE-2017-0199), Internet Explorer (CVE-2020-1380 and CVE-2020-26411), and Microsoft Edge (CVE-2021-26411) for execution.[2][1][3][4]
	Enterprise	T1204	Exploitation of Remote Services	APT37 has used exploits for Flash Player (CVE-2016-4117, CVE-2018-4878), Word (CVE-2017-0199), Internet Explorer (CVE-2020-1380 and CVE-2020-26411), and Microsoft Edge (CVE-2021-26411) for execution.[2][1][3][4]
	Enterprise	T1205	Exploitation of Remote Services	APT37 has used exploits for Flash Player (CVE-2016-4117, CVE-2018-4878), Word (CVE-2017-0199), Internet Explorer (CVE-2020-1380 and CVE-2020-26411), and Microsoft Edge (CVE-2021-26411) for execution.[2][1][3][4]
	Enterprise	T1206	Exploitation of Remote Services	APT37 has used exploits for Flash Player (CVE-2016-4117, CVE-2018-4878), Word (CVE-2017-0199), Internet Explorer (CVE-2020-1380 and CVE-2020-26411), and Microsoft Edge (CVE-2021-26411) for execution.[2][1][3][4]

Adobe

Task 6 - Threat Emulation Process III

5. Observe Results: The Blue Team analyzes logs, events, and network traffic to identify emulation activities and determine whether the simulated attack was successful, blocked, or detected. Detection methods such as **YARA rules** can help identify malicious activity.

6. Document & Report Findings: Teams document the emulation process, results, security impact, and recommendations. Reports provide evidence of security effectiveness and highlight improvements needed to strengthen defenses.

Answer the questions below

1. Click the View Site button at the top of the task to launch the static site. What is flag three obtained after completing the exercise?

THM{D3F3NC3_1N_3MUL4T10N}

While defending against APTs, what mitigation measure would you use to prevent Command and Scripting techniques?

MITRE ATT&CK mapping: Command and Scripting Interpreter → T1059

Mitigation: Execution Prevention (M1038)

Password Policies - Protects accounts, not command execution.

Privileged Account Management - Limits permissions, not execution.

Execution Prevention *** Blocks unauthorized programs and scripts from executing.

Antimalware - Detects malware but may not block all scripts.

How would you mitigate against data loss through ransomware encryption?

MITRE ATT&CK mapping: Data Encrypted for Impact → T1486

Mitigation: Data Backup (M1053)

Limit Hardware Installation - Controls devices, not ransomware recovery.

Remote Data Storage - Helps store data remotely but does not guarantee recovery.

Data loss prevention - Prevents unauthorized data transfer, not encryption recovery.

Data Backup *** Allows organizations to restore encrypted files after a ransomware attack.

What is the most efficient method used for data exfiltration?

Uploading files to cloud storage services - **Cloud storage:** Can be used but may leave traces.

Using email or file transfer protocols *** **Using email or file transfer protocols:** Common and efficient methods for attackers to transfer stolen data.

Using USB drives or other removable media - **USB drives:** Requires physical access.

Hiding data in images or other file types - **Steganography:** Hides data but is slower.

Using covert channels such as DNS or ICMP - **DNS/ICMP:** Covert but less efficient.

| The first ransomware that leveraged worm-like capabilities is known as

WannaCry * **WannaCry ransomware** — Used the EternalBlue exploit to spread automatically across networks like a worm.

Data Backup - A mitigation, not ransomware.

Cloud storage - Not ransomware.

DNS or ICMP - Network protocols, not ransomware.

| What is flag four obtained after completing the exercise?
THM{S3CUR3_4LL_W3B_4553T5}

| **When emulating a SQL injection attack, what indicators in web server logs can suggest it is successful?**

Increase in database errors - May indicate attempts but not always successful.

Presence of SQL syntax in logs *** Shows attackers are injecting SQL commands (e.g., `SELECT`, `UNION`, `OR 1=1`).

Abnormal database query patterns - Possible indicator, but harder to detect.

Unexpected data retrieved from the database - Usually confirmed after investigation.

| What kind of web server logs would effectively indicate brute-force attacks during the emulation and detection?

Multiple login attempts with different usernames - Could be password spraying.

Increase in failed login attempts - General indicator.

Repeated login attempts from the same IP address * Strong indicator of automated brute-force activity.

Sequential login attempts - Not always visible.

File inclusion attacks would be detected using which artefacts in web server logs?

Presence of path traversal syntax in logs * /etc/pass pass traversal attack -

Indicates attempts to access unauthorized files (e.g., `../etc/passwd`).

Unusual file retrieval requests - Possible indicator.

Increase in file retrieval errors - Less specific.

Unusual traffic patterns from specific IP addresses - Too broad.

Which group was responsible for breaches due to the exploitation of the Outlook web app?

SideCopy - A suspected Pakistan-linked APT group known for cyber espionage campaigns.

Inception - A cyber espionage group (also known as **Cloud Atlas**) targeting governments and organizations.

Hafnium ** A Chinese state-sponsored group known for exploiting Microsoft Exchange Server vulnerabilities (including Outlook Web App-related attacks).

BlackOasis - A cyber espionage group associated with using commercial spyware and targeting individuals/organizations.

Task 7 - Conclusion

Threat emulation follows a structured process to replicate adversary behaviors and improve an organization's security posture. Although often associated with Red Teams, it requires collaboration across all security teams. Understanding attacker techniques helps defenders improve detection, response, and overall cybersecurity resilience.

